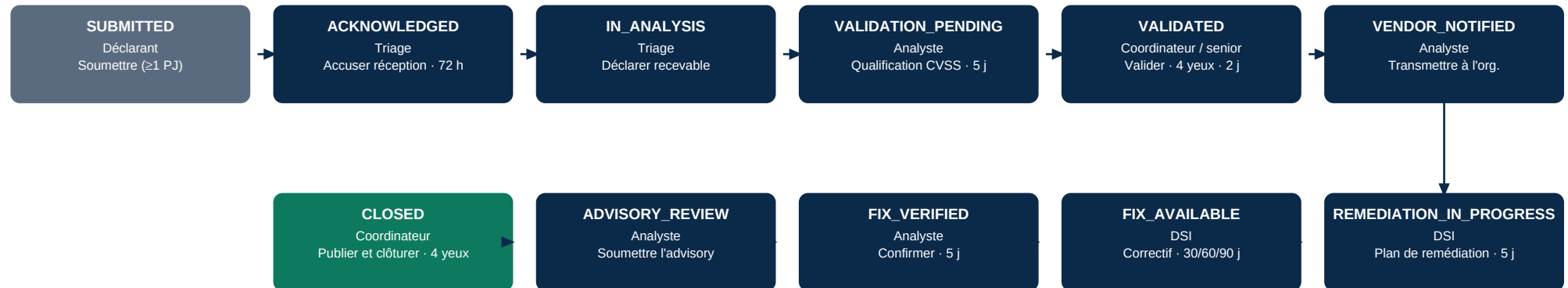


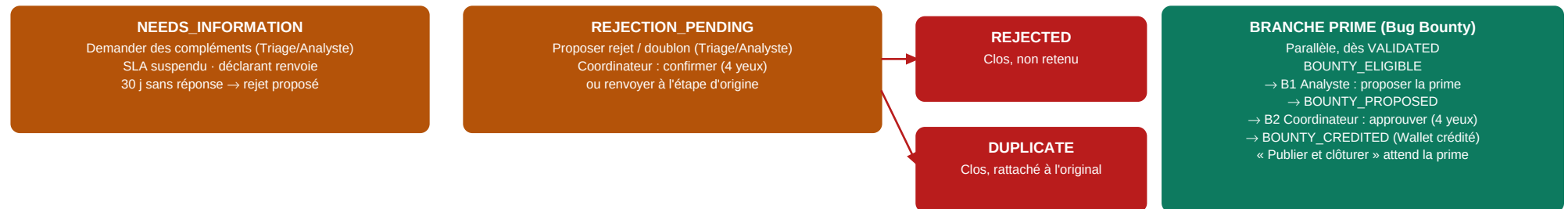
eVDP — Workflow v2 et matrice RBAC

Workflow effectivement implémenté dans la plateforme (branche **weno**). Source de vérité : `apps/coordination/workflow.py` et `apps/accounts/roles.py`. Chaque étape a un seul propriétaire et un seul bouton ; l'interface guide, le serveur décide (`check_transition()`) ; chaque clic, refus compris, est audité.

Chemin principal : 1 étape = 1 bouton = 1 rôle (le libellé indique le rôle propriétaire et le bouton qui fait passer au statut)



Sorties d'exception (actions secondaires, commentaire obligatoire) — depuis les étapes 1 à 3



Renvois : Coordinateur → analyste (étapes 4 et 10, B2) · « Correctif insuffisant » (étape 8 → 7) · Escalade : SLA dépassé (auto) ou Coordinateur (étapes 6-7), sans changement de statut.

1. Chemin principal (11 étapes)

#	Statut de départ	Rôle propriétaire	Bouton unique	Pré-requis bloquants	Statut d'arrivée	SLA
0	—	Déclarant	Soumettre le rapport	Formulaire complet, ≥ 1 pièce jointe (PDF, Word, images, texte, archives ; fichiers à macros refusés)	SUBMITTED	—
1	SUBMITTED	Agent de triage	Accuser réception	Dossier ouvert au moins une fois	ACKNOWLEDGED	72 h
2	ACKNOWLEDGED	Agent de triage	Déclarer recevable	Checklist : périmètre, organisation identifiée, PJ lisible	IN_ANALYSIS	5 j avec l'étape 3
3	IN_ANALYSIS	Analyste CSIRT	Soumettre la qualification	Vecteur CVSS v3.1 ou v4.0 saisi par un analyste, CWE, organisation	VALIDATION_PENDING	5 j
4	VALIDATION_PENDING	Coordinateur ou analyste senior	Valider la qualification	Valideur ≠ auteur (4 yeux), commentaire	VALIDATED	2 j
5	VALIDATED	Analyste CSIRT	Transmettre à l'organisation	Version « organisation » du rapport (identité protégée)	VENDOR_NOTIFIED	—
6	VENDOR_NOTIFIED	Responsable DSI	Accepter et soumettre le plan de remédiation	Plan + date cible ≤ 30 / 60 / 90 j selon sévérité	REMEDATION_IN_PROGRESS	5 j
7	REMEDATION_IN_PROGRESS	Responsable DSI	Déclarer le correctif disponible	Description, version ou date de déploiement	FIX_AVAILABLE	30 à 90 j
8	FIX_AVAILABLE	Analyste CSIRT	Confirmer le correctif	Compte rendu de contre-vérification	FIX_VERIFIED	5 j
9	FIX_VERIFIED	Analyste CSIRT	Soumettre l'advisory	Brouillon assaini : aucun PoC, aucune IP, aucune URL	ADVISORY_REVIEW	—
10	ADVISORY_REVIEW	Coordinateur	Publier et clôturer	Relecture (≠ auteur), commentaire, prime créditée ou non éligible	CLOSED	—

Délai de remédiation : Critique 30 j, Élevée 60 j, Moyenne et Faible 90 j. Kanban : badge vert, orange à 75 % du délai, rouge à échéance. Un SLA dépassé escalade automatiquement le dossier.

2. Branche Bug Bounty et Wallet

#	Statut prime	Rôle	Bouton unique	Pré-requis	Arrivée
B1	BOUNTY_ELIGIBLE	Analyste CSIRT	Proposer la prime	Montant de la matrice ; hors palier = justification écrite	BOUNTY_PROPOSED
B2	BOUNTY_PROPOSED	Coordinateur	Approuver et créditer le Wallet	Approbateur ≠ proposeur, commentaire	BOUNTY_CREDITED

Statut de prime distinct du statut du dossier. Programme VDP → NOT_ELIGIBLE à la validation. Wallet = grand livre d'écritures (crédit, ajustement, versement hors plateforme), solde calculé, jamais stocké ni modifiable. Aucun flux financier réel.

3. Sorties d'exception (actions secondaires, commentaire obligatoire)

Action	Déclenchée par	Étapes	Effet	Retour
Demander des compléments	Triage, Analyste	1 à 3	NEEDS_INFORMATION, SLA suspendu	Déclarant : « Envoyer les compléments » → étape d'origine ; 30 j sans réponse → rejet proposé automatiquement
Proposer le rejet	Triage, Analyste	1 à 3	REJECTION_PENDING	Coordinateur : confirmer → REJECTED (4 yeux), ou renvoi à l'étape d'origine
Marquer comme doublon	Triage, Analyste	1 à 3	REJECTION_PENDING (motif doublon)	Coordinateur confirme → DUPLICATE, rattaché à l'original sans fuite vers le déclarant

Action	Déclenchée par	Étapes	Effet	Retour
Renvoyer à l'auteur	Coordinateur	4, 10, B2	Retour à l'étape précédente	—
Correctif insuffisant	Analyste	8	Retour en REMEDIATION_IN_PROGRESS	—
Escalader	Automatique (SLA) ou Coordinateur	6, 7	Alerte rouge, notification du Coordinateur	Le Coordinateur peut décider une divulgation à échéance

4. Contrôles serveur — check_transition()

#	Contrôle	En cas d'échec
1	La transition existe pour le statut courant	Refus « action impossible » (400 API)
2	Le dossier est dans le périmètre de l'utilisateur	404 (jamais 403 : l'existence n'est pas confirmée)
3	L'utilisateur possède la capacité de la transition	Refus « capacité requise » (403 API)
4	Les pré-requis de l'étape sont remplis	Bouton grisé + liste explicite (400 API, champ « missing »)
5	Quatre yeux : acteur ≠ auteur de l'étape précédente (et ≠ auteur du CVSS à l'étape 4)	Refus « règle des quatre yeux » (403 API)
6	Commentaire obligatoire (étapes 4, 10, B2 et exceptions)	Refus « commentaire obligatoire »

Le refus est audité hors transaction ; l'application est atomique et auditée.

5. Matrice de visibilité des données

Donnée	Déclarant	Triage	Analyste	Coordinateur	DSI / Resp. org	Auditeur	Super admin
Rapport et pièces jointes	Lecture (les siens)	Lecture	Lecture	Lecture	Version organisation, dès l'étape 5	Métadonnées	—
Identité du chercheur	Complet (la sienne)	Lecture	Lecture	Lecture	Pseudonyme ou rien	Pseudonymisée	—
Score et vecteur CVSS	—	Lecture	Complet	Lecture	Score final	Lecture	—
Notes internes (triage, analyse)	—	Complet	Complet	Lecture	—	—	—
Canal chercheur	Complet	Complet	Complet	Complet	—	—	—
Canal CSIRT ↔ organisation	—	Complet	Complet	Complet	Complet	—	—
Wallet	Lecture (le sien)	—	—	Complet	—	—	—
Brouillon d'advisory	—	—	Complet	Lecture (relecture)	Lecture	Lecture	—
Journal d'audit	—	—	—	Lecture	—	Complet (+ exports)	Logs techniques

Le déclarant voit un statut simplifié à 5 paliers (Reçu, En analyse, Validé, En correction, Publié) et seulement les jalons publics de la chronologie. Son formulaire ne contient pas de qualification technique. Anonymat et crédit public s'excluent. Pièces du déclarant en lecture seule pour tous.

6. Rôles : boutons, droits et interdictions

Rôle spec v2	Rôle(s) dans le code	Boutons de workflow	Actions secondaires	N'a pas le droit de
CHERCHEUR_VDP	SECURITY_RESEARCHER, BUG_BOUNTY_RESEARCHER, PUBLIC_USER	Soumettre le rapport	Envoyer les compléments	Voir le CVSS interne, les notes internes, le canal organisation, les dossiers des autres
TRIAGER	TRIAGER	Accuser réception, Déclarer recevable	Compléments, proposer rejet / doublon	Saisir le CVSS, valider une qualification, proposer une prime, publier
CSIRT_ANALYST	CSIRT_ANALYST	Qualifier, Transmettre à l'org., Confirmer le correctif, Soumettre l'advisory, Proposer la prime	Compléments, rejet, doublon, correctif insuffisant	Valider sa propre qualification, approuver une prime, publier
NAT_COORDINATOR	NATIONAL_COORDINATOR (+ analyste senior : permission individuelle pour l'étape 4)	Valider la qualification, Approuver et créditer le Wallet, Publier et clôturer	Confirmer rejet / doublon, renvoyer, escalader	Modifier les preuves, valider ce qu'il a qualifié, approuver une prime qu'il a proposée, réécrire l'advisory
VENDOR_ADMIN	DSI_ADMIN, ORGANIZATION_MANAGER	Plan de remédiation, Correctif disponible	—	Rejeter, voir le Wallet, contacter le chercheur, voir son identité, voir les autres organisations
(hors spec)	AUDITOR	Aucun	—	Voir les PoC ou l'identité réelle, agir sur un dossier
(hors spec)	SUPER_ADMIN	Aucun (comptes, rôles, configuration, SLA, matrices de prime)	—	Lire le contenu des dossiers, cliquer un bouton de workflow (ISO/IEC 27001 A.5.3)

7. Comptes de démonstration (seed_demo)

Rôle	Compte	Étapes qu'il réalise
Agent de triage	triage@csirt.bf	1, 2 ; compléments, rejet, doublon
Analyste CSIRT	analyste@csirt.bf	3, 5, 8, 9, B1
Coordinateur national	coordinateur@anssi.bf	4, 10, B2 ; confirmations, renvois, escalade
DSI (organisation)	dsi@sante.gov.bf	6, 7
Chercheur / Chercheur Bug Bounty	researcher@demo.bf / bugbounty@demo.bf	0 ; envoi des compléments
Auditeur	auditeur@evdp.bf	Lecture seule (métadonnées, journal d'audit)

Les comptes métiers (tous sauf chercheurs) exigent la double authentification TOTP. Réinitialisation : `docker compose exec evdp-web python manage.py reset_mfa <email>`, puis nouvelle connexion pour scanner un nouveau QR code.